Análise de arquivo malware

Share

codigo.py

PY

Analise o arquivo em anexo passo a passo e determine ao final: este arquivo é benigno ou é um malware?

Verificando as instruções de leitura de arquivos

Vou começar consultando a orientação para leitura de arquivos enviados e, em seguida, ler o conteúdo do arquivo. A análise será estática, sem executar o código.

Read 2 files, ran a command

Ainda estou lendo o arquivo (já passei de 950 das 1.221 linhas). Falta o trecho final, onde ficam a instalação de pacotes, a criação dos serviços systemd e o fluxo principal.

Read a file, ran a command

É malware. Mais precisamente, é um worm de SSH que se auto-replica: varre a internet, tenta entrar em servidores com senhas fixas, copia a si mesmo para os que cedem e reporta tudo ao atacante via Telegram. A análise foi estática: li o código inteiro, sem executá-lo.

Análise passo a passo

1. **Aspecto geral.** São 1.221 linhas de Python em texto puro, sem ofuscação (nada de `eval`, `exec` ou base64). Os comentários estão em chinês simplificado, o que sugere o idioma do autor, mas não prova origem. O arquivo embute três scripts Python (`ssh_scanner.py`, `filter_files.py`, `ip_port_extractor.py`), um shell (`run_scan.sh`) e um `monitor_script.py`.
2. **Prepara o ambiente como root.** O `main()` só prossegue se for root e instala `masscan`, `screen`, `python3` e `paramiko` via apt/yum/dnf. Se o apt estiver ocupado, ele espera um pouco e depois mata `apt` / `dpkg` e apaga os locks à força, o que é incomum em software legítimo.
3. **Baixa e executa código remoto sem verificação.** Ele baixa `install.sh` e `install_tm.sh` de `del.sou.pp.ua` e roda ambos com `bash` como root, sem hash nem assinatura.
   - O primeiro usa o nome de um agente de monitoramento conhecido (Komari), mas vem de um domínio do autor, então não há como saber o que faz.
   - O segundo menciona no próprio código o diretório do Traffmonetizer e recebe um token embutido. Isso indica monetização da banda da vítima em benefício do atacante.
   - Também baixa `ip_ranges.txt` (faixas de IP a atacar) e `del.txt` (alvos já processados).

- Esses arquivos remotos não foram analisados, então o impacto real pode ser maior do que o visível aqui.

4. **Varre a internet em loop infinito.** O `run_scan.sh` roda `masscan` nas portas 22 e 5522 a 5.000 pacotes/s sobre as faixas baixadas. Em seguida extrai os pares `ip:porta`, remove os já processados e recomeça, sem fim.
5. **Tenta adivinhar senhas (password spraying).** O `ssh_scanner.py` tenta login como `root` em cada alvo com apenas duas senhas fixas, `LeitboGi0ro` e `123@@@`, em várias threads. Os hosts que aceitam são gravados em `LeitboGi0ro.txt` ou `q123.txt` numa pasta oculta.
6. **Se propaga.** É a parte que o torna um worm.
   - O `monitor_script.py` vigia esses arquivos a cada 10 s e consulta uma API do atacante (`sou.pp.ua/check_ip.php`) para não repetir alvos.
   - Depois entra na máquina nova via SSH e envia por SFTP uma cópia **deste mesmo arquivo** para `/tmp/bendi.py`.
   - Instala Python se faltar, executa como root, apaga a cópia e registra o alvo em `add_ip.php`.
   - Cada vítima vira um novo scanner, então o crescimento é exponencial.
7. **Reporta ao atacante.** A cada invasão bem-sucedida, ele envia ao Telegram um relatório com host, usuário, senha usada e resultado. O bot e o chat estão embutidos nas linhas 409–410.
8. **Persiste e se esconde.**
   - Instala tudo em diretórios ocultos com nomes que imitam o sistema (`/usr/lib/.sysd-scan/`, `/usr/lib/.sysd-monitor/`, `/var/lib/.sysd-data/`).
   - Cria duas units systemd como root, com `Restart=always` e nomes banais (`scan-runner.service`, `file-monitor.service`). As senhas e o token do bot ficam em `Environment=` nelas.
   - No fim, apaga o próprio arquivo dois segundos depois de concluir.

Por que não é uma ferramenta legítima. Peças isoladas como masscan, paramiko e systemd são de uso duplo e comuns. O que decide é a combinação: não há autorização nem escopo, os alvos vêm de um servidor do autor e as senhas são fixas. Há ocultação em pastas disfarçadas, autodeleção, replicação automática e envio de credenciais a um terceiro. Uma ferramenta de auditoria ou pentest não se esconde, não se apaga e não se espalha sozinha.

Indicadores para busca (IOCs)

- SHA256: `bc3cba42cc93d83b54f5a00f06c6e395366a884b0bd2825828afaba2dcd008fa`
- Caminhos: `/usr/lib/.sysd-scan/`, `/usr/lib/.sysd-monitor/`, `/var/lib/.sysd-data/`, `/var/log/.sysd-monitor.log`, `/tmp/bendi.py`
- Serviços: `scan-runner.service`, `file-monitor.service`
- Domínios: `sou.pp.ua`, `del.sou.pp.ua`
- Telegram: bot de ID 7431501378 e chat 743493786 (o token completo está na linha 409)
- Senhas testadas: `LeitboGi0ro`, `123@@@`

- Rede e processos: tráfego intenso de saída para as portas 22/5522 e sessões `screen` chamadas `masscan_scan_*` e `ssh_scan_*`

Conclusão

O arquivo é **malware**: um worm de SSH com password spraying, persistência oculta, instalação de payloads remotos e exfiltração de credenciais via Telegram. Não o execute fora de uma VM isolada e sem rede.

Se ele chegou a rodar em alguma máquina, trate-a como comprometida: isole da rede e prefira reinstalar a partir de uma imagem limpa, já que os scripts remotos podem ter feito mais do que se vê aqui. Depois, troque as credenciais e desative o login de root por senha no SSH. Se algum servidor seu usa as duas senhas listadas, considere-o invadido. Vale também denunciar o bot ao Telegram e o domínio ao registrador e à hospedagem.

Se quiser, posso montar um checklist para verificar se algum dos seus servidores foi afetado.

Qual é a categoria principal deste malware?

Classificando o tipo de ameaça e suas funções secundárias

A categoria principal é **worm (verme de rede)**, mais especificamente um worm de SSH.

O que o define como worm é que ele se propaga sozinho, sem interação do usuário. Cada máquina infectada varre a internet, invade novos servidores por SSH e envia uma cópia do próprio código para eles. A vítima nova repete o ciclo.

Além disso, ele combina outras funções:

- **Dropper/loader:** baixa e executa scripts remotos como root, vindos de um servidor do autor.
- **Botnet/infraestrutura de varredura:** cada host infectado vira um nó de scanner, coordenado por uma API central.
- **Sequestro de recursos (resource hijacking):** instala um cliente de monetização de banda (Traffmonetizer) com token do atacante. É uma variação do cryptojacking, só que lucrando com banda em vez de CPU.
- **Roubo de credenciais:** envia ao Telegram do atacante o host, o usuário e a senha de cada invasão.

O vetor de infecção é o password spraying (poucas senhas fixas contra muitos hosts), e não uma vulnerabilidade de software. Servidores com SSH exposto e senha fraca são o alvo.